

****SEE ALSO:**** Newsletter of August 9, 2024

[doc. web n. 10042684]

Provision of June 6, 2024

Register of provisions

n. 340 of June 6, 2024

****THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA****

IN THE meeting today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, members, and
Secretary General Fabio Mattei;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016 (hereinafter, GDPR);

HAVING REGARD TO the Code regarding the protection of personal data, containing provisions for the adaptation of the national legal system to Regulation (EU) 2016/679 (Legislative Decree of June 30, 2003, n. 196, as amended by Legislative Decree of August 10, 2018, n. 101, hereinafter, Code);

HAVING REGARD TO the complaint submitted pursuant to Article 77 of the GDPR by Ms. XX, through Attorney XX against the Company Drivalia Leasys Rent S.p.A. (hereinafter, Leasys Rent S.p.A.) and CA Autobank S.p.A. (formerly, FCA Bank S.p.A.);

HAVING EXAMINED the documentation on file;

HAVING REGARD TO the observations made by the Secretary General pursuant to Article 15 of the Guarantor's Regulation n. 1/2000;

REPORTING by Dr. Agostino Ghiglia;

****PREMISE****

1. ****Complaint.****

With a complaint dated March 25, 2021, the complainant represented that Leasys Rent S.p.A. (hereinafter, the Company) had denied her the voucher for the rental of a car because she was listed as "included in a blacklist."

In particular, in response to the request to exercise her rights submitted on October 28, 2020, by the interested party to the Company, the latter communicated that "at the booking stage, [...] it verifies the data of the contracting party through databases of the FCA Bank S.p.A. Group with the specific aim of preventing fraud and insolvencies or other similar events [...] and that each rental request is subjected to an examination based on objective elements that take into account all the elements present in the databases of the FCA Bank Group in order to assign a synthetic judgment on the degree of reliability and solvency of the applicant." Subsequently, on December 9, 2020, the interested party sent to the Company and to CA Autobank S.p.A. (formerly, FCA Bank S.p.A., hereinafter, the Bank), an additional request aimed at knowing "what data and/or personal information they had in their possession that caused the denial of contractual negotiations, her inclusion in the 'Blacklist' and lastly also the accusation of being a 'bad payer' (although nothing appears in CRIF)." Since this request, according to the complainant, remained unanswered, she submitted the complaint under examination to this Authority.

2. ****The investigative activity.****

2.1 ****Requests for information.****

In relation to the facts referred to in the complaint, the office initiated a complex investigative activity both against the Bank and against the Company (with reference to the latter, the relevant outcomes are contained in a separate provision, adopted on the same date). In this context, the Bank, with notes dated July 7, 2021, and July 15, 2022, was invited to provide the necessary clarifications regarding the

facts subject to the complaint. In the response provided on July 26, 2021, the Bank represented that it had never been approached for service requests by the complainant and that it carried out, on behalf of the Company, “certain activities to verify the data provided by the interested parties in the databases used by it solely for the purpose of preventing fraud and insolvencies or other similar events,” from which, with reference to the complainant, “a negative output was obtained regarding the income documents from the SCIPAFI application (centralized computer system for administrative prevention of identity theft, a tool of the Ministry of Economy and Finance), communicated to Leasys Rent based on the above.” With a subsequent note dated August 3, 2022, the Bank supplemented the previous response, specifying that:

- “FCA Bank is the parent company of the eponymous banking group and holds 100% of the share capital of Leasys Rent”;
- in the “management of compliance with personal data protection regulations [...] and specifically regarding the processing of personal data, specific agreements have been established to regulate intercompany relations between the parent company and its subsidiaries, including measures aimed at mitigating the risk of identity theft and fraud.”
- the Bank and the Company have signed a so-called Data Processing Agreement (hereinafter “DPA”), the logic of which is to regulate “the relationship between a 'Data Controller' (each of the controlled companies) and a 'Processor' (the parent company), delegating to the latter the possibility of carrying out certain types of services, on behalf of the Data Controller, which also involve the processing of personal data,” including “the activities of verifying the accuracy of the personal data entered by individuals interested in renting a vehicle”;
- “the legal basis that justified and legitimized the processing of personal data is represented by the execution of the contract, the aforementioned DPA, [...] which lists the type of activities that FCA Bank carries out on behalf of Leasys Rent”;
- “the purpose of the processing, which takes into account the control activities carried out, regulated by the same DPA, is to be identified in the need to protect the companies of the group, in this case Leasys Rent, from acquiring customers that may pose a risk of fraud and/or other potentially harmful elements.”
- in this specific case, “from the results of the checks carried out by FCA Bank, at the request of Leasys Rent, “a negative output was found regarding the Income Documents from the SCIPAFI application (Centralized Computer System for Administrative Prevention of Identity Theft), a tool of the Ministry of Economy and Finance,” income documents that were not requested either by Leasys Rent or by FCA Bank [...]. The lack of evidence of the submission of the income tax return was communicated to Leasys Rent for its determinations, in accordance with what is provided for by the aforementioned DPA.”

2.2 The request for clarifications made to the Ministry of Economy and Finance.

The office requested clarifications from the Ministry of Economy and Finance (MEF) regarding access to the income data of the complainant contained in the SCIPAFI System, carried out by the Bank on behalf of the Company, in order to assess whether to accept the rental request.

The MEF, in its response, stated that the Bank, pursuant to Article 30-ter, paragraph 5, letter a) of Legislative Decree 141/2010, is required to participate, as a direct member, in the fraud prevention system.

The Ministry also stated that it had authorized, with a note dated July 6, 2022, the same Bank “to make inquiries in the SCIPAFI System on behalf of Leasys Rent S.p.A. [...], by virtue of the provision in paragraph 7-bis of Article 30-ter of Legislative Decree 141/2010: this is because Leasys Rent S.p.A., a long-term rental company, is not a company included among those participating in the Identity Theft Prevention System pursuant to Article 30-ter, paragraph 5 of the aforementioned legislative decree.”

In particular, the MEF assessed to include the case of long-term rental in Legislative Decree 141/2010, in line with what is provided by the Circular issued on July 17, 2014, by the V Directorate for the Prevention of the Use of the Financial System for Illegal Purposes. The latter, in fact, establishes that, without prejudice to the subjective scope of application of the regulation (as defined by Article 30-ter of

Legislative Decree 141/2010), paragraph 7-bis of the aforementioned Article 30-ter of the decree should be interpreted as expanding the objective scope of application of the norm, thus allowing the adhering subjects to make use of the prevention system even outside the cases provided for in paragraph 7 of the same regulatory provision.

2.3. The inspection activity.

In exercising the control powers referred to in Article 58, paragraph 1 of the GDPR (see also Articles 157 and 158 of the Code) and in order to conduct a thorough examination of the matter, the Authority also proceeded to carry out an investigation at the Bank (see minutes of operations carried out on April 4, 2023), during which it emerged:

- that “at the stage of opening a leasing application, financing for the purchase of a car, personal loan, or opening a deposit account, the data of the interested party are loaded through various entry channels: mostly through a dealer, via the SellFi platform, or through digital channels through which the customer accesses a loading portal”;
- that the bank provides the Company with a watchlist “that reports the reason for the anomaly exclusively in the form of a numerical code” and that “is accessed only through automatic calls from the systems, apart from the possibility of access by a small group of authorized individuals, part of the fraud team, and some customer care resources”;
- with reference to the specific case, the accesses to SCIPAFI concerning the interested party were four: “the first 3 [...] accesses were made by FCA Bank at the time of the long-term rental request to Leasys,” regarding the fourth, the Bank reserved the right to provide further clarifications.

On April 21, 2023, the Bank, in sending the supplementary documentation to resolve the reservations, preliminarily stated that it had “modified its shareholding structure and is now wholly owned by Credit Agricole Consumer Finance S.A., a French banking group that is itself wholly owned by the Credit Agricole S.A. banking group; on the same date, it also changed its corporate name to CA Auto Bank S.p.A.”

In this circumstance, the Bank, with specific reference to the complainant's case, also pointed out that:

- “its name, as of the date of the inspection, had already been removed from the Watch List”;
- the three accesses to SCIPAFI in 2019 were related to the assessment of the subject for the granting of the long-term rental requested from Leasys: normally, in case of a negative outcome on some data, analysts try to carry out various searches in the system in order to overcome any prejudicial issues.

Following the analysis carried out, the outcome was nonetheless a refusal;

- considering that on November 5, 2020, the Company had requested further information regarding the customer's watchlist notification, in relation to the exchange.

of the context in which the agreement was made, including the roles and responsibilities of each party involved in the data processing activities.”

4. The Response of the Bank.

On October 27, 2023, the Bank submitted its defense documents in which it:

- confirmed that the authorization from the Ministry of Economy and Finance (MEF) for the Company's (indirect) access to SCIPAFI occurred after the Company had actually accessed the information [...], present in the watchlist made available by the Bank.
- reiterated that the Company has never processed the specific personal information present in SCIPAFI related to the Claimant, but could only view, through consultation of the watchlist provided by the Bank, a numerical code corresponding to “counterfeit income documentation”;
- clarified, regarding the roles (data controller and data processor) to be assigned to the Company and the Bank concerning the processing of the data in question, that the qualification as “exemplary and non-exhaustive” of the profiles listed in the Data Processing Agreement (DPA) of 2019, contained in the communication sent on August 3, 2022, in response to the request for information sent by the Authority on July 15, 2002, had the sole “purpose of avoiding listing all the cases explicitly mentioned in the 2019 DPA,” therefore the Company, “while fully aware that the 2019 DPA was undoubtedly improvable,” believes “that such informational deficiencies [do] not even undermine the requirements set forth in Article 28(3) GDPR, resulting in a de facto lack of regulation in this regard. In fact, the requirements of the aforementioned Article 28(3) cannot be considered absent: in the recitals, in

addition to the specific purposes of the processing, the regulated matter and the nature of the processing are present and/or deducible; the categories of data subjects and the type of personal data are reported, respectively, in Articles 2 and 3; the obligations and rights of the controller can be found in numerous articles, including, by way of example, in Article 5 regarding sub-processors”;

- specified that “the renewal of the aforementioned DPA 2019 is not, in fact, a renewal nor an agreement within the meaning of Article 28 GDPR, but rather a true service contract (hereinafter also referred to as the “Service Contract”) to which the aforementioned DPA necessarily relates even if not explicitly referenced”;

- referred to Article 10.1 of the aforementioned Contract which states that “with regard to the data that will be provided in the performance of the Services, each Party, as an independent data controller, commits to full compliance with the regulations on personal data protection [...]” and confirmed “the ambiguity of the aforementioned wording [...] concerning the independent ownership of the parties, specifying that “this provision must necessarily be interpreted in accordance with the principles of contractual interpretation set forth in Articles 1362 et seq. of the Civil Code. These provisions impose a comprehensive reading that takes into account not only the 2019 DPA but also, and above all, the context in which the agreement was made, including the roles and responsibilities of each party involved in the data processing activities.”

of the following paragraph of the same Article 10, which states that the Bank is “authorized to process personal data exclusively in execution of the obligations provided for in this contract and, in particular, for the execution of the services covered by it.” The presence of such a provision is a clear indicator of the impossibility of attributing independent ownership to each of the parties and would instead confirm “a relationship between the data controller (Drivalia) and the data processor (Bank) in execution of the aforementioned DPA 2019”;

- confirmed “the involvement of the data protection officer in relation to the aforementioned contracts. However, there is no formal opinion from the latter as it is not required by the regulations.”

4. The regulatory framework.

4.1. The SCIPAFI system: Article 30-ter of Legislative Decree No. 141 of August 13, 2010.

The SCIPAFI system, established at the Ministry of Economy and Finance - which has entrusted its management to Consap S.p.A - is a public system for the administrative prevention of fraud in the consumer credit sector and deferred or delayed payments, with specific reference to identity theft (see Legislative Decree No. 141/2010 and the decree of the Ministry of Economy and Finance of May 19, 2014, No. 95).

Access to the System and the information contained therein is restricted to subjects explicitly identified by the regulations, qualified as adherents (Article 30-ter, paragraphs 5 and 5-bis, of the cited Legislative Decree).

The processing of personal data of the interested parties within the archive (both by the MEF and by Consap and the adhering subjects) is permitted solely for the purposes identified by Article 2, paragraph 2 of Ministerial Decree 95/2014, namely the verification of the authenticity of the data contained in the documentation provided by individuals (as interested parties) who request a deferral or delay of payment, a loan, or other similar financial facilitation, a deferred payment service and “in cases where they deem it useful, based on the assessment of the acquired elements, to ascertain their identity” (Article 30-ter paragraphs 7 and 7-bis of the cited Legislative Decree 141/2010).

4.2. Relevant provisions regarding the protection of personal data.

The processing of personal data must take place in compliance with the principles indicated in Article 5 of the GDPR, including those of “lawfulness, fairness, and transparency” (Article 5, paragraph 1, letter a) of the GDPR).

The regulations concerning the protection of personal data identify the subjects - data controller and data processor - who, in different capacities, may process the personal data of the interested parties, also establishing their respective attributions.

In this context, the data controller is the subject responsible for decisions regarding the purposes and methods of processing the personal data of the interested parties and on whom, pursuant to Article 24 of the GDPR, a “general responsibility” (accountability) falls for the processing of personal data carried out directly or by others acting “on its behalf,” namely the data processors (recital 81, Articles 4, point 8) and 28 of the GDPR).

The relationship between the data controller and the data processor must be governed by a contract, or another legal act, executed in writing, which, in addition to mutually binding the two parties, provides instructions to the processor and specifies in detail (and exhaustively, and not merely exemplarily) what the subject matter is, the duration, the nature and purposes of the processing, the type of personal data and categories of interested parties, the obligations and rights of the controller.

5. The Authority's assessments and the outcome of the investigation.

Following the examination of the statements made by the Bank during the proceedings (for which the author is responsible for the truthfulness under the effects of Article 168 of the Code “Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or exercise of the powers of the Guarantor”) as well as the documentation acquired in the records, the following observations are made.

In particular:

a. in relation to the lawfulness of the processing of the data of the interested party, taken from SCIPAFI, the Bank, confirming that the authorization of the MEF for access made on behalf of the Company to the SCIPAFI System was granted on July 6, 2022, and therefore on a date subsequent to that on which the processing of the interested party's data occurred, also specified that it has never “proceeded with the processing of the specific personal information present in SCIPAFI related to the Claimant,” having exclusively made available to the Company the numerical code (present in the aforementioned watchlist provided by the Bank to the group companies) that indicated as “counterfeit” the income documentation related to the interested party.

In this specific case, therefore, the accesses to SCIPAFI made by the Bank, on behalf of the Company, in order to assess the position of the claimant, occurred between 2019 and 2020, a period during which, as evidenced by the documentation on file, the Company (which is not among the adherents to the SCIPAFI System, specifically identified by Article 30-ter, paragraph 5, of the cited Legislative Decree No. 141/2010) was not authorized, even through the Bank, to access SCIPAFI and to acquire and process the data present therein related to the interested party (even if reprocessed and made available to the Company through the so-called watchlist created by the Bank), in order to evaluate whether to enter into the car rental contract. Such processing is therefore illegality.

It is also noted that the SCIPAFI system allows for the verification of the authenticity of the data contained in the documents (identity or income) presented by the interested party for the purpose of evaluating a request. It therefore presupposes that the adherent conducts a specific verification regarding a specific document presented to obtain the requested service;

In this case, the access made by the Bank on behalf of the Company is illegal as it occurred without having conducted such verification; in fact, it appears that the income declaration of the claimant was never acquired, a document essential for making the comparison with the income information related to the same contained in SCIPAFI.

b. in relation to the subjective role (of data controller or processor) held by the Company and the Bank concerning access to the data of the interested party drawn from SCIPAFI and subject to subsequent processing and inclusion in the watchlist, the Bank itself, while declaring itself aware that the documentation produced (in particular, the DPA 2019 and the subsequent act called “renewal” of 2020) is unclear on this point, believes, however, that such deficiencies do not undermine the requirements set forth in Article 28, paragraph 3 of the GDPR and that a relationship of controller and processor respectively emerges from the documents in relation to the Company and the Bank.

- In this regard, it is noted that, at the time of the events, the Bank, as an independent data controller,

was authorized to access SCIPAFI exclusively within the scope of carrying out its specific activity (Article 30-ter, paragraphs 7 and 7-bis, Legislative Decree 141/2010, cited); conversely, in this case, access was made to evaluate the position of the interested party for the purpose of entering into a rental contract (which falls outside the Bank's activities) with the Company (which constitutes a subject different from the Bank, although belonging to the same group).

It follows, therefore, that the Bank acted in violation of Article 28, paragraph 3 of the GDPR, since it processed the data of the interested party that it could not process as a processor on behalf of the Company, as the latter was not among the subjects that, at the time of the events, could access SCIPAFI either directly or through subjects adhering to the System.

6. Conclusions: illegality of the processing carried out.

In light of the evaluations that precede, it is noted that the statements made by the data controller in the defense writings - the truthfulness of which may be subject to accountability under Article 168 of the Code - do not allow for overcoming all the observations notified by the Office with the initiation of the procedure and are insufficient to allow for its archiving, as none of the cases provided for by Article 11 of the regulation of the Guarantor No. 1/2019, concerning internal procedures of the Authority with external relevance, apply.

The processing carried out by the Bank is illegal in the terms outlined above, in relation to Articles 5, paragraph 1, letter a) and 28 of the GDPR.

The violation of the aforementioned provisions entails the application of the administrative sanction provided for by Article 83, paragraph 4, letter a); paragraph 5, letter a) of the GDPR.

7. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i), and 83 of the Regulation; Article 166, paragraph 7, of the Code).

The Guarantor, pursuant to Article 58, paragraph 2, letter i) of the Regulation and Article 166 of the Code, has the power to impose an administrative pecuniary sanction provided for by Article 83, paragraph 5, of the Regulation, by adopting an injunction order (Article 18, Law No. 689 of November 24, 1981).

The violation, ascertained in the terms outlined in the motivation, cannot be considered "minor," taking into account the nature, severity, degree of responsibility, and the manner in which the supervisory authority became aware of the violation (Recital 148 of the Regulation).

With reference to the elements listed in Article 83, paragraph 2, of the Regulation for the purpose of applying the administrative pecuniary sanction and its quantification, considering that the sanction must "in any case [be] effective, proportionate, and dissuasive" (Article 83, paragraph 1 of the Regulation), it is represented that, in this case, the following circumstances have been considered:

- in relation to the nature and severity of the violation, the nature of the violation concerning the organization of the entire processing with reference to the roles respectively held by the Bank and the Company at the time the event occurred has been deemed relevant, specifically regarding the lawfulness of the processing of data related to the interested party;
- in relation to the intentional or negligent nature of the violations, account must be taken of the conduct of the Bank, which deemed it appropriate to access SCIPAFI on behalf of a group Company, while being aware that this occurred in the absence of authorization from the MEF;
- the cooperation provided by the Bank during the investigation and the adjustments made in compliance with the principle of accountability, by establishing a new, more structured contractual arrangement, having signed a new service contract with an attached new agreement pursuant to Article 28 of the GDPR;
- the absence of previous rulings by the Authority against the Bank regarding the same case, as well as similar complaints to that subject of the present provision.

Considering the aforementioned principles of effectiveness, proportionality, and deterrence to which the Authority must adhere in determining the amount of the sanction (Article 83, paragraph 1, of the Regulation), it is deemed that the economic conditions of the offender, determined based on the revenues achieved by the Company with reference to the ordinary financial statements for the year 2022, are relevant in this case.

It is also considered necessary to apply paragraph 3 of Article 83 of the Regulation, which states that

"If, in relation to the same processing or related processing, a data controller [...] violates, with intent or negligence, various provisions of this regulation, the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation," the total amount of the sanction is calculated so as not to exceed the maximum penalty provided for by the same Article 83, paragraph 5, letter a), of the Regulation.

In light of the above-mentioned elements and the assessments made, it is deemed, in this case, to apply against FCA Bank S.p.A. "now, CA Auto Bank S.p.A." (C.F./P.I. 08349560014) the administrative sanction of the payment of a sum of one million euros (euro 1,000,000.00).

In this context, it is also considered, taking into account the type of violations ascertained, that pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Guarantor no. 1/2019, the publication of this provision on the Guarantor's website should proceed and that the conditions of Article 17 of Regulation no. 1/2019 are met.

ALL OF THE ABOVE CONSIDERED, THE GUARANTOR

finds the illegality of the processing carried out by CA Autobank S.p.A. (formerly, FCA Bank S.p.A.) - C.F./P.I. 08349560014 -, represented by the legal representative pro tempore, with registered office in Turin, Corso Orbassano 367, pursuant to Article 143 of the Code, for the violation of Articles 12, paragraph 3, and 15 of the Regulation;

ORDERS

pursuant to Article 58, paragraph 2, letter i), of the Regulation, CA Autobank S.p.A. (formerly, FCA Bank S.p.A.) to pay the sum of one million euros (euro 1,000,000.00) as an administrative pecuniary sanction for the violations indicated in this provision;

REQUIRES

therefore the same Bank to pay the aforementioned sum of one million euros (euro 1,000,000.00) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts pursuant to Article 27 of Law no. 689/1981. It is reminded that the offender retains the option to settle the dispute by paying – always according to the methods indicated in the annex – an amount equal to half of the imposed sanction, within the term provided for the filing of the appeal as indicated below (Article 166, paragraph 8, of the Code);

DISPOSES

the publication of this provision on the Guarantor's website pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Guarantor no. 1/2019, and considers that the conditions of Article 17 of Regulation no. 1/2019 are met.

Pursuant to Article 78 of the Regulation, as well as Articles 152 of the Code and 10 of Legislative Decree no. 150/2011, an appeal against this provision may be filed with the ordinary judicial authority, with a petition submitted to the ordinary court of the place identified in the same Article 10, within thirty days from the date of communication of the provision itself, or sixty days if the appellant resides abroad.

Rome, June 6, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Ghiglia

THE SECRETARY GENERAL

Mattei